Triaging reported phishing emails

ANALYST	ROLE	ENVIRONMENT	HANDLING
Adi Prasetyo	Incident Responder	Training lab	Sanitised, no flags

SUMMARY

I analysed the sample emails provided in the room to decide whether each one was malicious and what should be blocked, using header analysis, authentication checks and safe handling of links and attachments.

SCOPE

Sample .eml messages supplied by the lab. No live mailbox or production data was involved.

METHOD

1. Opened the raw source and reviewed From, Return-Path, Reply-To, the Received chain and the originating IP.
2. Read the SPF, DKIM and DMARC results in the Authentication-Results header.
3. Extracted and defanged every URL, then checked its reputation.
4. Hashed each attachment and looked the hash up before uploading anything to a public sandbox.
5. Classified the lure type and wrote a verdict for each sample.

FINDINGS

- For every sample I recorded: display name versus real sending domain, Return-Path and Reply-To alignment, authentication results, URL destinations and attachment hashes.
- Authentication results alone were not enough for a verdict. Header alignment and link destinations had to be read together.
- Specific verdicts and indicators are left out so the room is not spoiled.

RECOMMENDATIONS

- Block the sender domain, URLs and attachment hashes at the email gateway.
- Search other mailboxes for the same sender or subject and remove the message.
- Contact recipients. If anyone clicked or entered credentials, reset them and review sign-ins.
- Move DMARC towards quarantine or reject, and keep a one-click report button for users.

WHAT THIS MEANS FOR THE ROLE

Headers show where an email really came from, and the body shows what the attacker wants. Looking up hashes before uploading keeps the investigation from tipping off the attacker.